

Comparison of Private Key Protection Techniques for Digital Identity Wallets

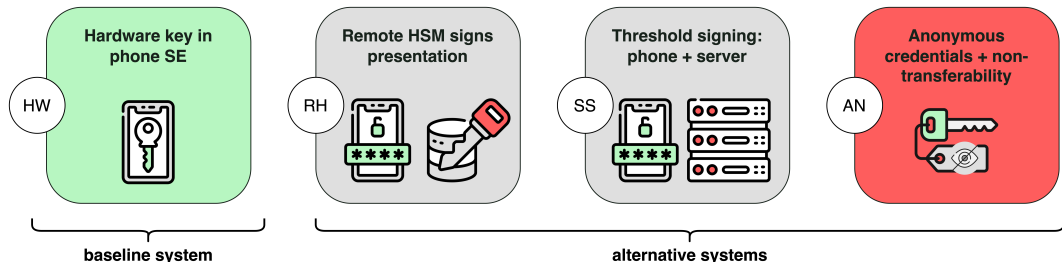
Jelizaveta Vakarjuk, Alisa Pankova, Aivo Kalu

Motivation

- Increased attention to the digital identity management systems
- Most of the solutions rely on user's mobile device
- **Question:** protection of the user's private key(s) on the mobile device

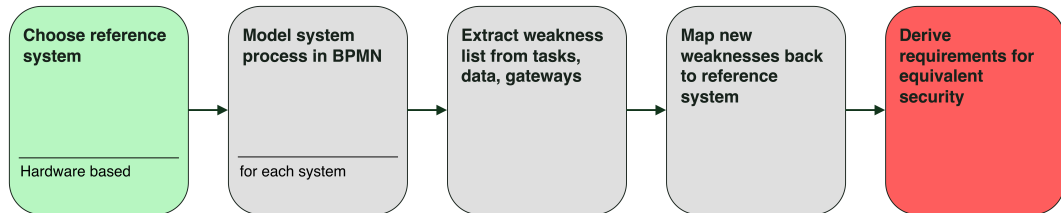
This work

The goal of this work is to evaluate whether the three alternative systems are at least as secure as the baseline system



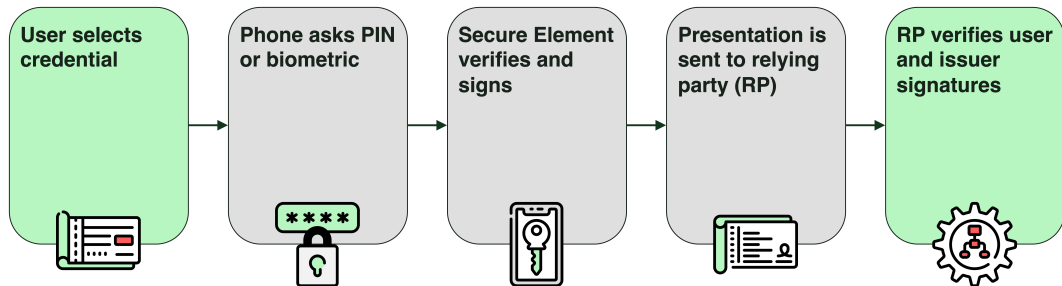
Methodology

Comparison methodology that identifies system weaknesses and maps them across compared systems



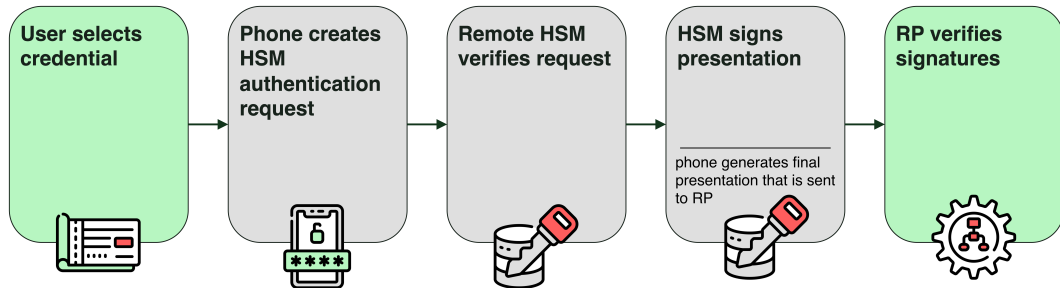
Hardware based credential

Private key stays inside the Secure Element on the mobile device



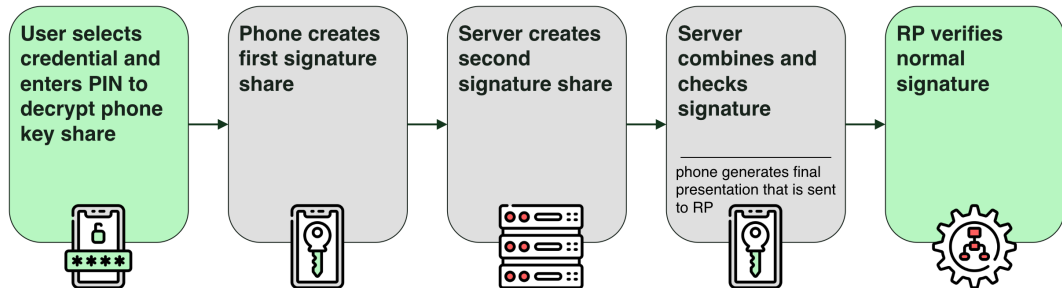
Remote HSM

The mobile device authenticates to a remote hardware module, which signs the presentation



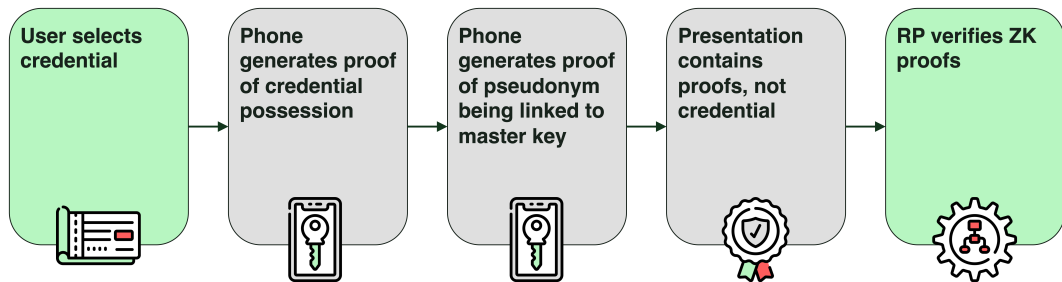
Threshold cryptography

The signing key is split between phone and supporting server



Anonymous credentials

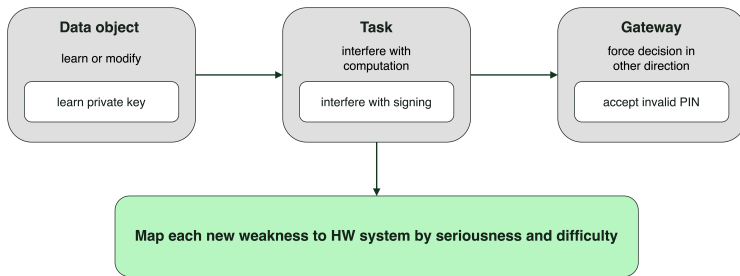
All-or-nothing non-transferability discourages sharing the master secret key



Identification of weaknesses

Each new weakness in RH, SS or AN is mapped to an equivalent weakness of HW by seriousness and/or difficulty

This mapping assumes that specific security measures are implemented in RH, SS or AN



Main identified requirements

System	Condition
Remote HSM	Remote HSM must be strongly protected from unauthorized access
Server-supported signing	Server-side key share must be stored in an HSM; clone detection and offline PIN-guessing protection should be used
Anonymous credential	Needs additional private-key protection, such as Secure Element storage or threshold cryptography

Remote HSM

- Equivalent to HW if the Remote HSM is protected at least as well as the local Secure Element
- It can even improve resistance to the offline PIN guessing because authentication happens on the server side
- It shifts trust from the phone to central infrastructure, so compromise of the HSM could affect many users

Server - supported signing

- Equivalent to HW if the supporting server's key share is stored in HSM
- Potentially stronger approach than HW because an attacker must compromise both the mobile device and the server-side component to create credential presentations

Anonymous credential

- Provide non-transferability, but if the master secret is stolen, the attacker can present credentials and potentially learn information about all of the user's credentials
- To be equivalent to HW, the anonymous credential system needs extra key-protection mechanisms, such as Secure Element storage or threshold cryptography

Main result

Alternative systems are at least as secure as, the hardware-based system with respect to the identified weaknesses in terms of seriousness, and in many cases also in terms of difficulty of exploitation

*Equivalence depends on extra assumptions and implementation requirements

Main result II

Alternative systems provide even greater protection against certain attacks than baseline system

Server-supported system with addition of non-transferability can provide best protection against attacks on user's secret and knowledge factor compared to other systems

Thank you!

- Questions?



[cybernetica](#)



[Cybernetica](#)



[cybernetica_ee](#)



[Cybernetica](#)